INTRODUCTION TO INFORMATION SECURITY

WEEK2

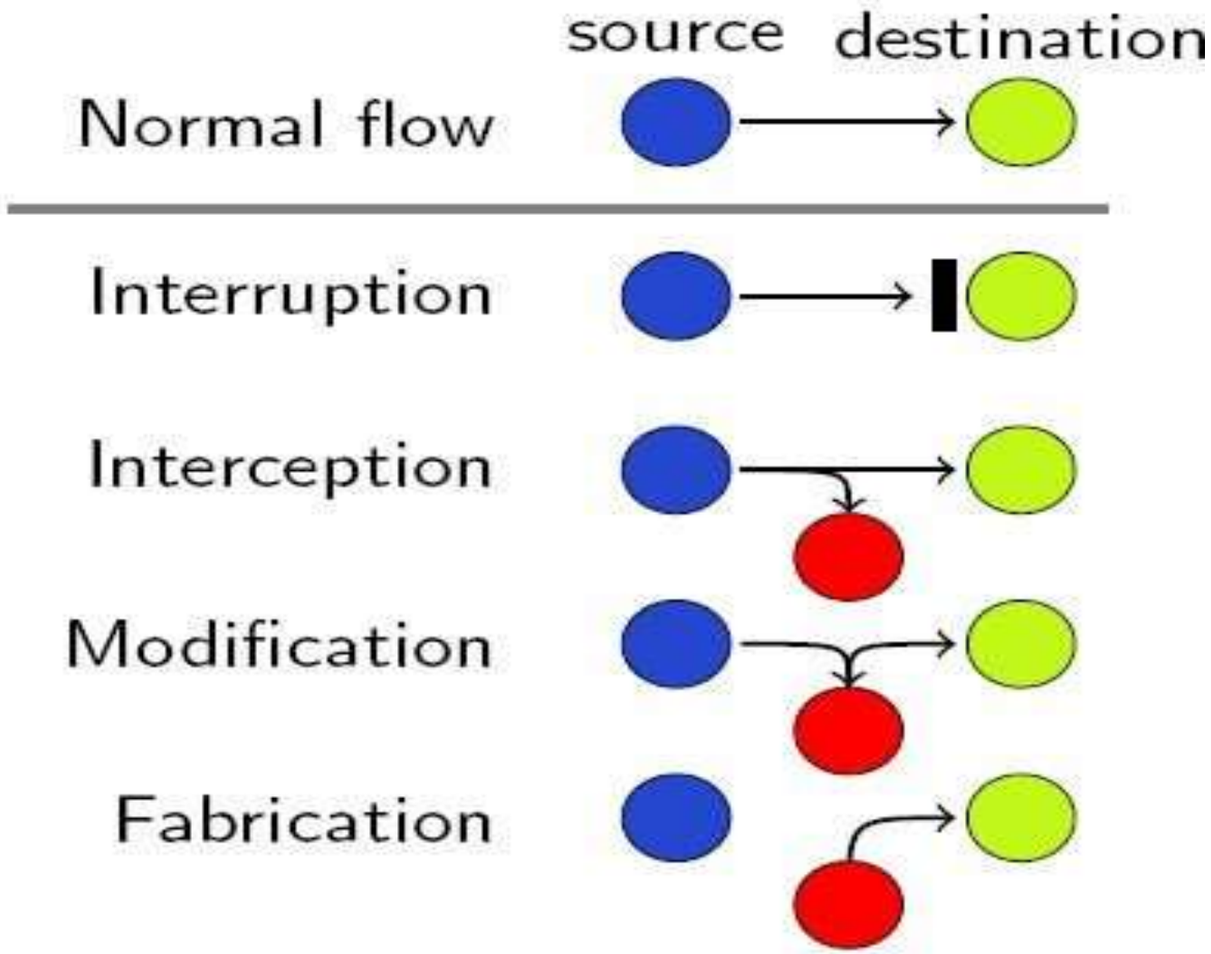
CLO Covered in this Lecture:

CLO1: Explain key information security concepts and legal, ethical, and professional issues in information security.

Security Attack

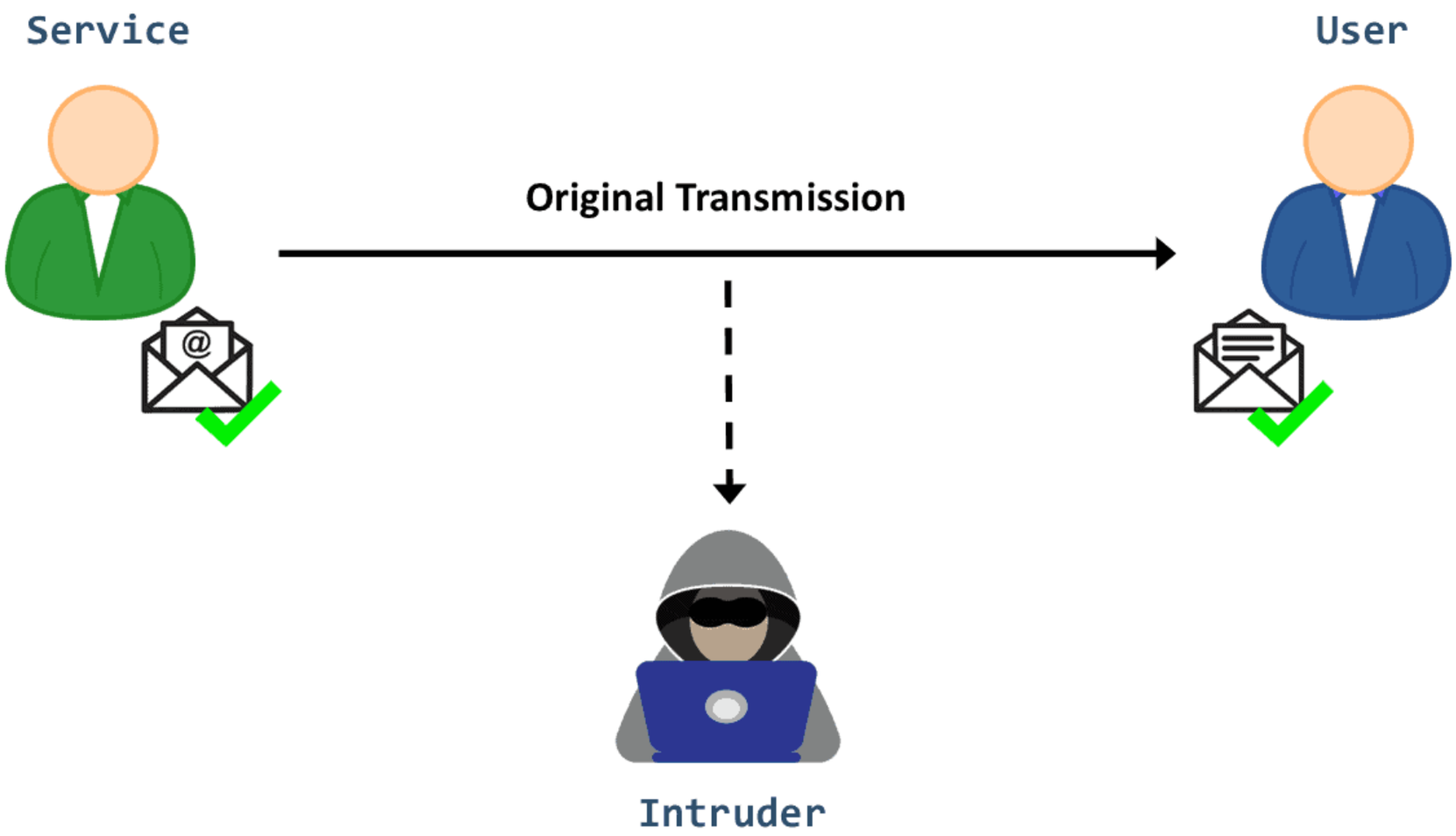
- "Any action that compromises the security of information owned by an organization"
- Information security is about how to prevent attacks, or failing that, to detect attacks on information-based systems
- Often *threat* & *attack* used to mean same thing
- Have a wide range of attacks
- Can focus of generic types of attacks
  - passive
  - active

Security Attacks

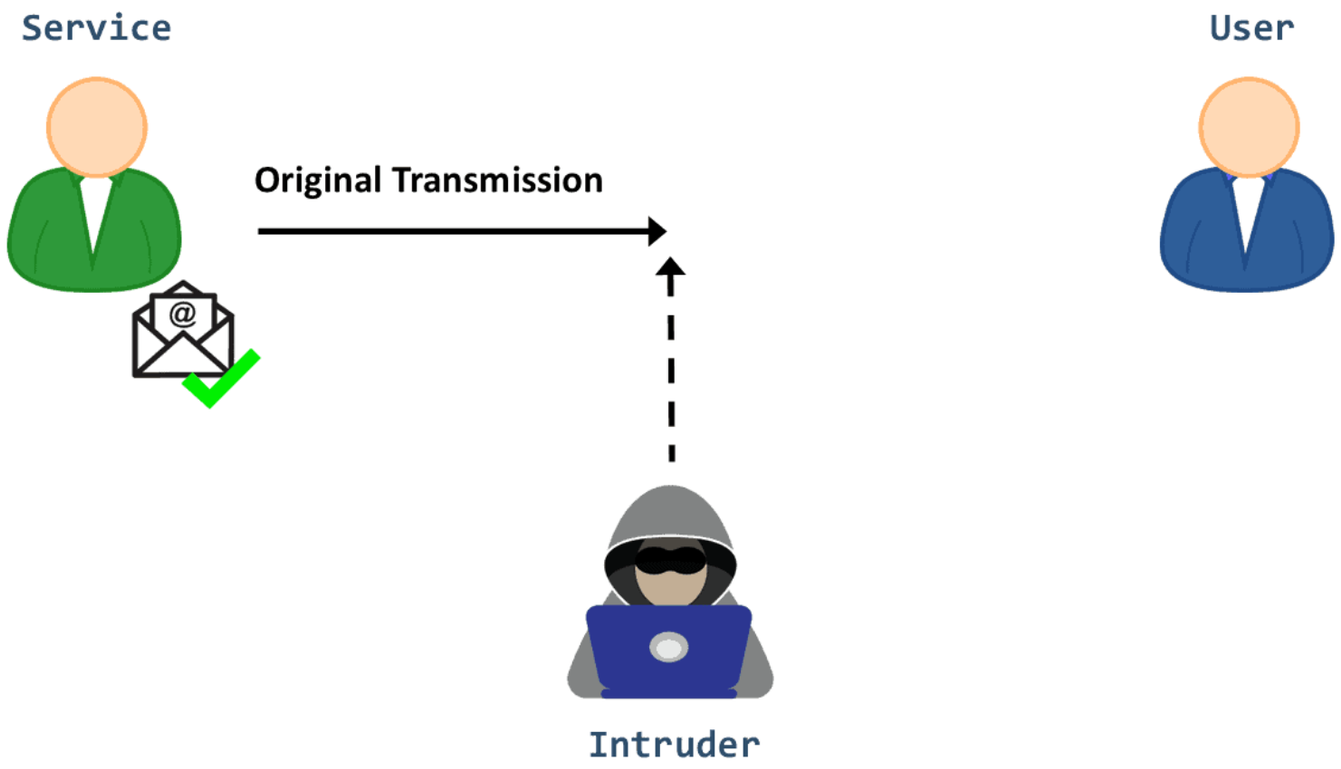


Data Communication

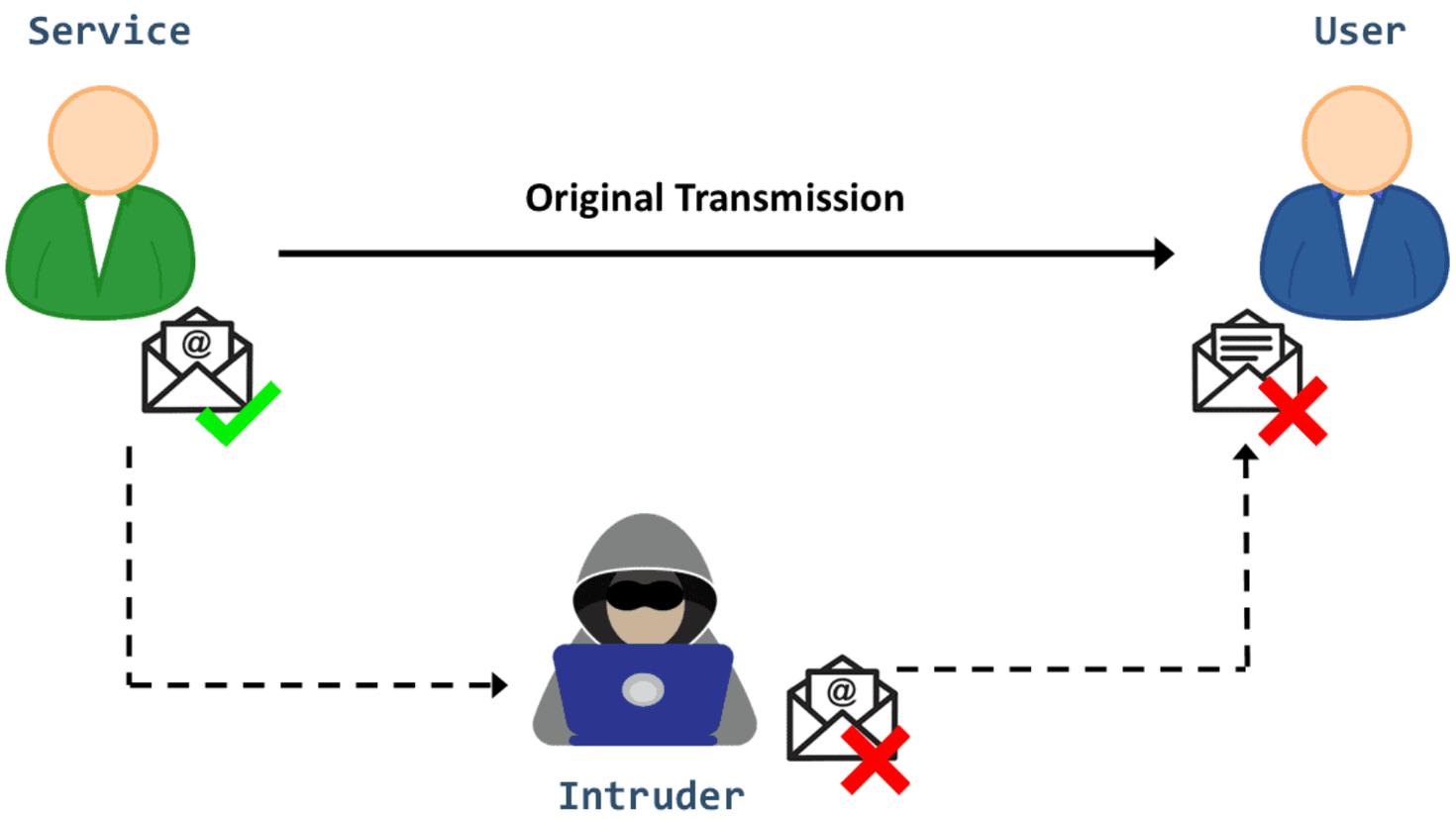
Interception



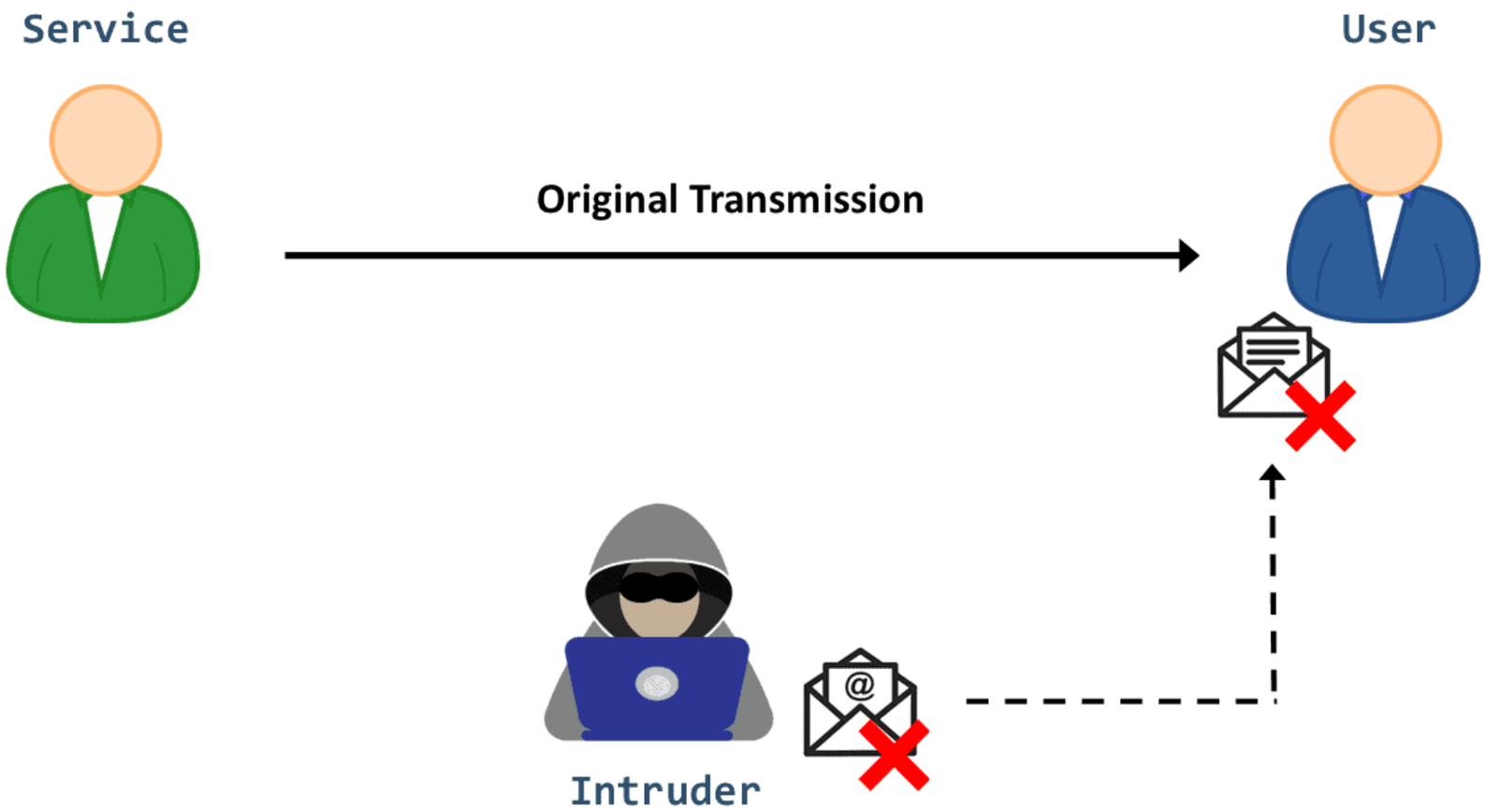
Interruption



Modification



Fabrication

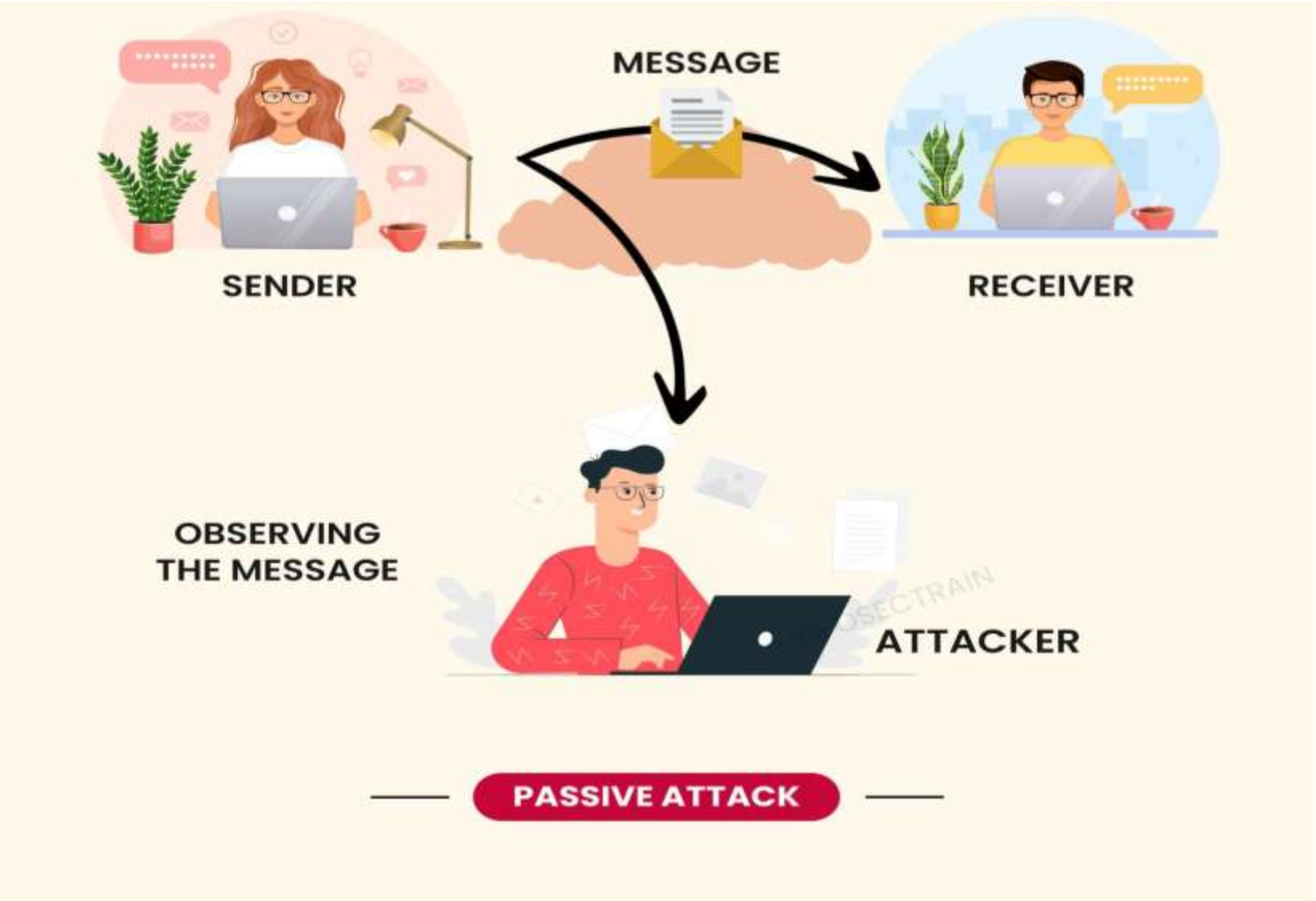


Attack Category	Characteristics	Examples	Type
Interception	An unauthorized actor access a service or information shared between two legitimate users	• Eavesdropping • Passwords attacks • Packet sniffing	Passive
Interruption	An unauthorized actor disrupts a service or destroys hardware	• Hardware disruption • Message corruption • Denial of Service • Malware	Active
Modification	An unauthorized actor gains access to a service or data and tampers with the content	• MITM attack • Cross-Site Scripting (XSS)	Active
Fabrication	An unauthorized actor inserts malicious data in the system	• Spoofing • SQL Injection • Phishing • Replay attacks	Active

Passive Attacks

- **“Passive attacks”** attempt to learn or make use of information from the system but does not affect system resources.
- By spying on, or monitoring of, transmissions to:
  - obtain message contents or
  - monitor traffic flows
- Are difficult to detect because they do not involve any alteration of the data.

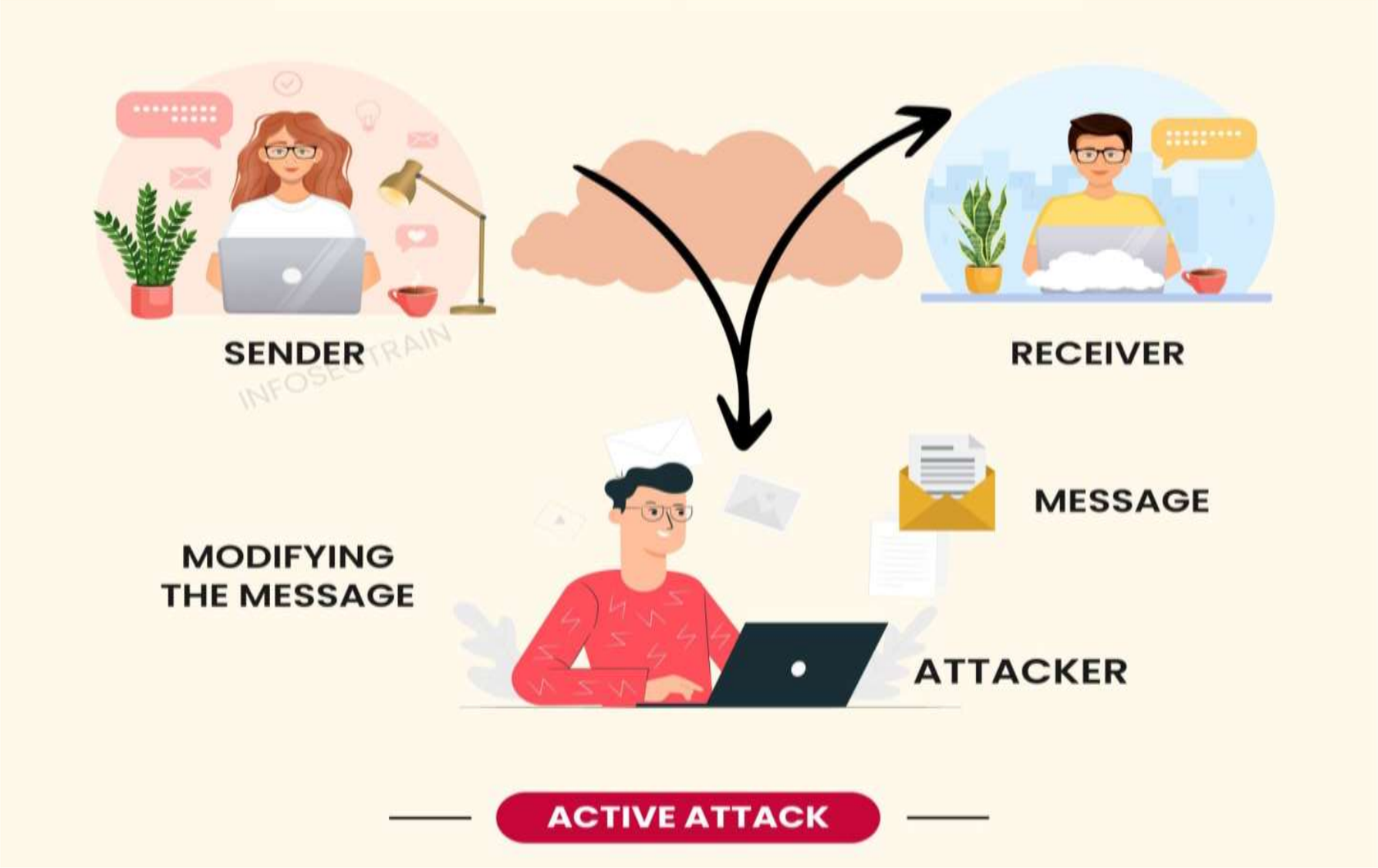
Passive Attacks



Active Attacks

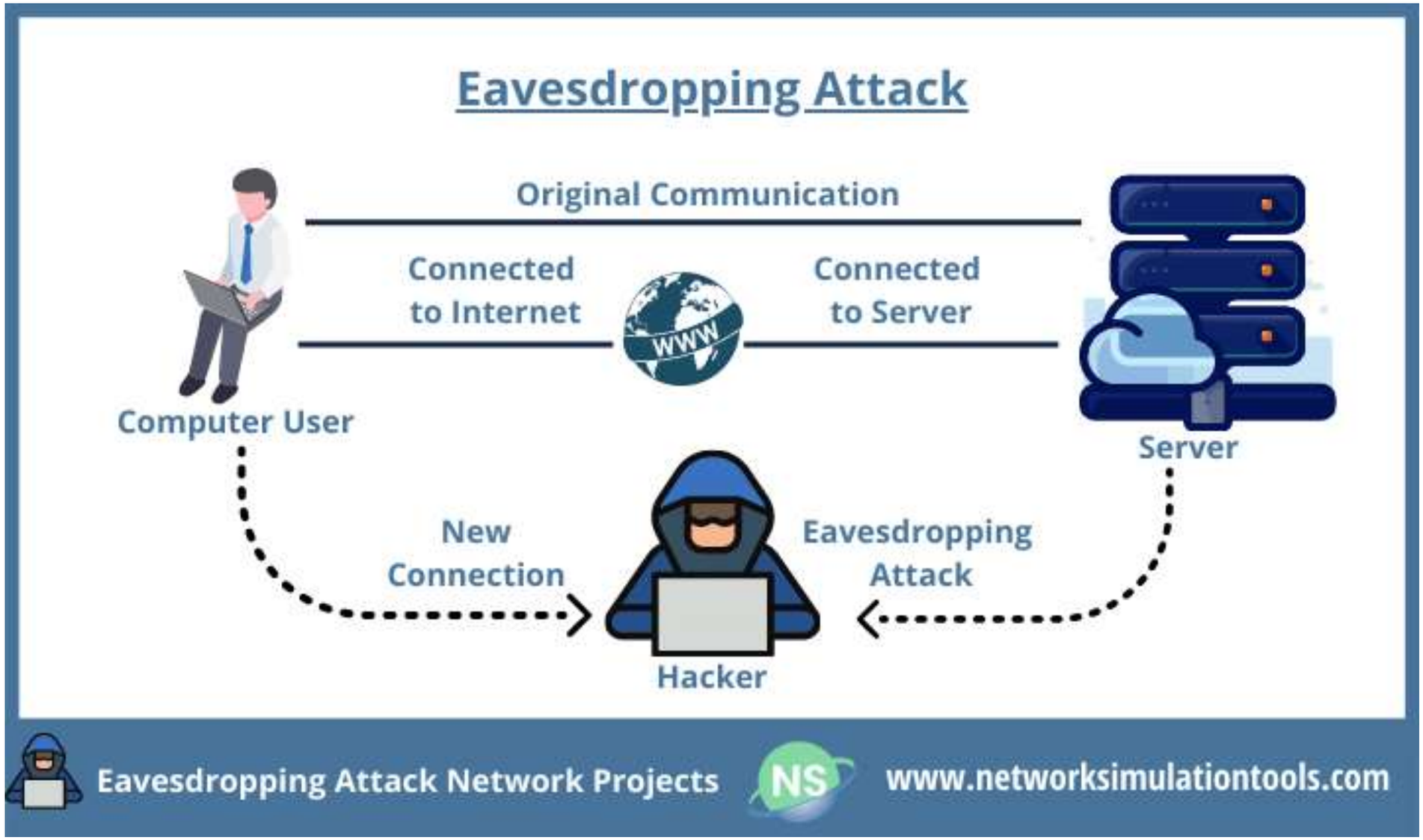
- **“Active attacks”** attempt to alter system resources or affect their operation.
- Active attacks are relatively easier to detect. Measures are available to prevent their success.
- On the contrary, it is quite difficult to prevent active attacks because of the wide variety of potential physical, software, and network vulnerabilities.
- Instead, the goal is to detect active attacks and to recover from any disruption or delays caused by them.

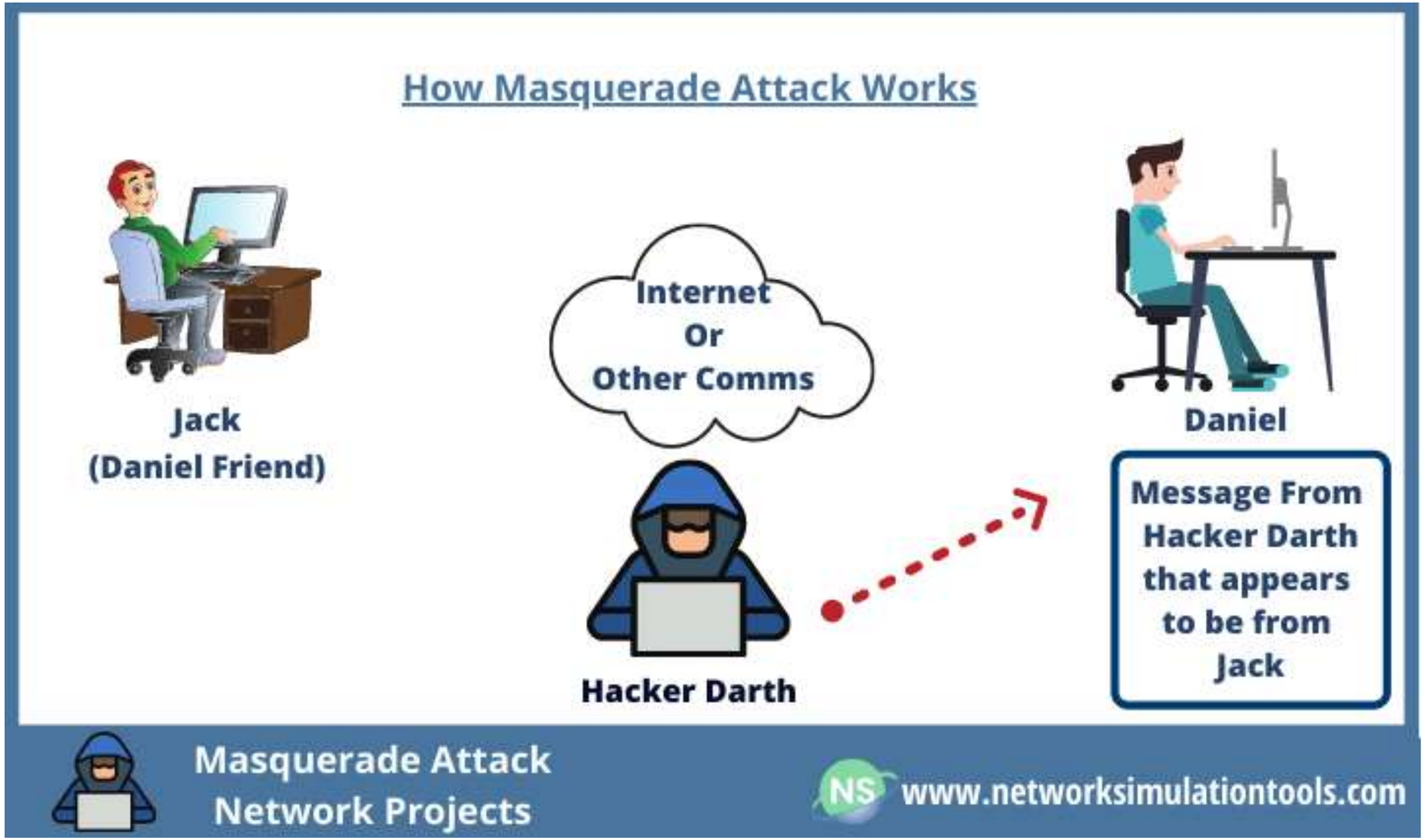
Active Attacks

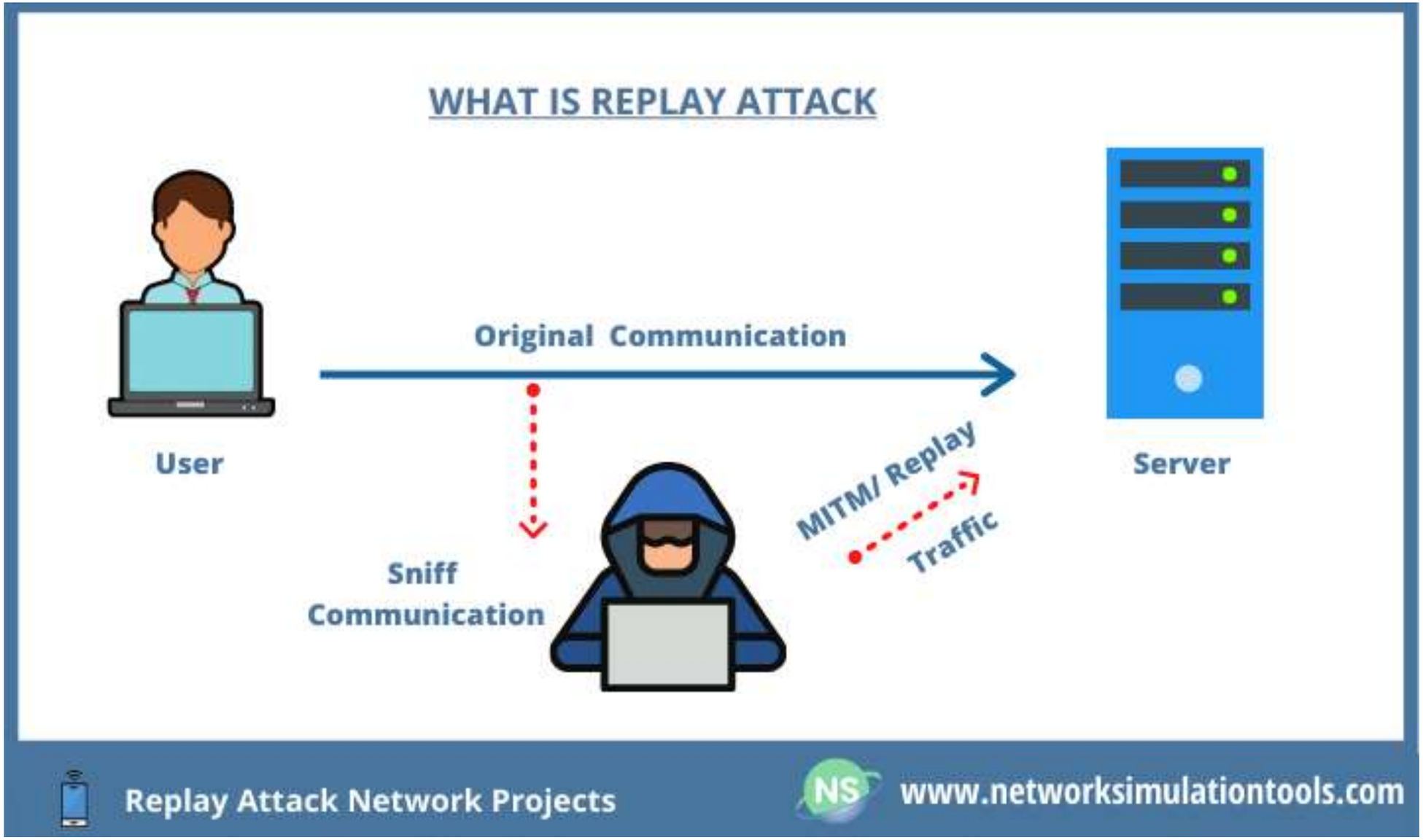


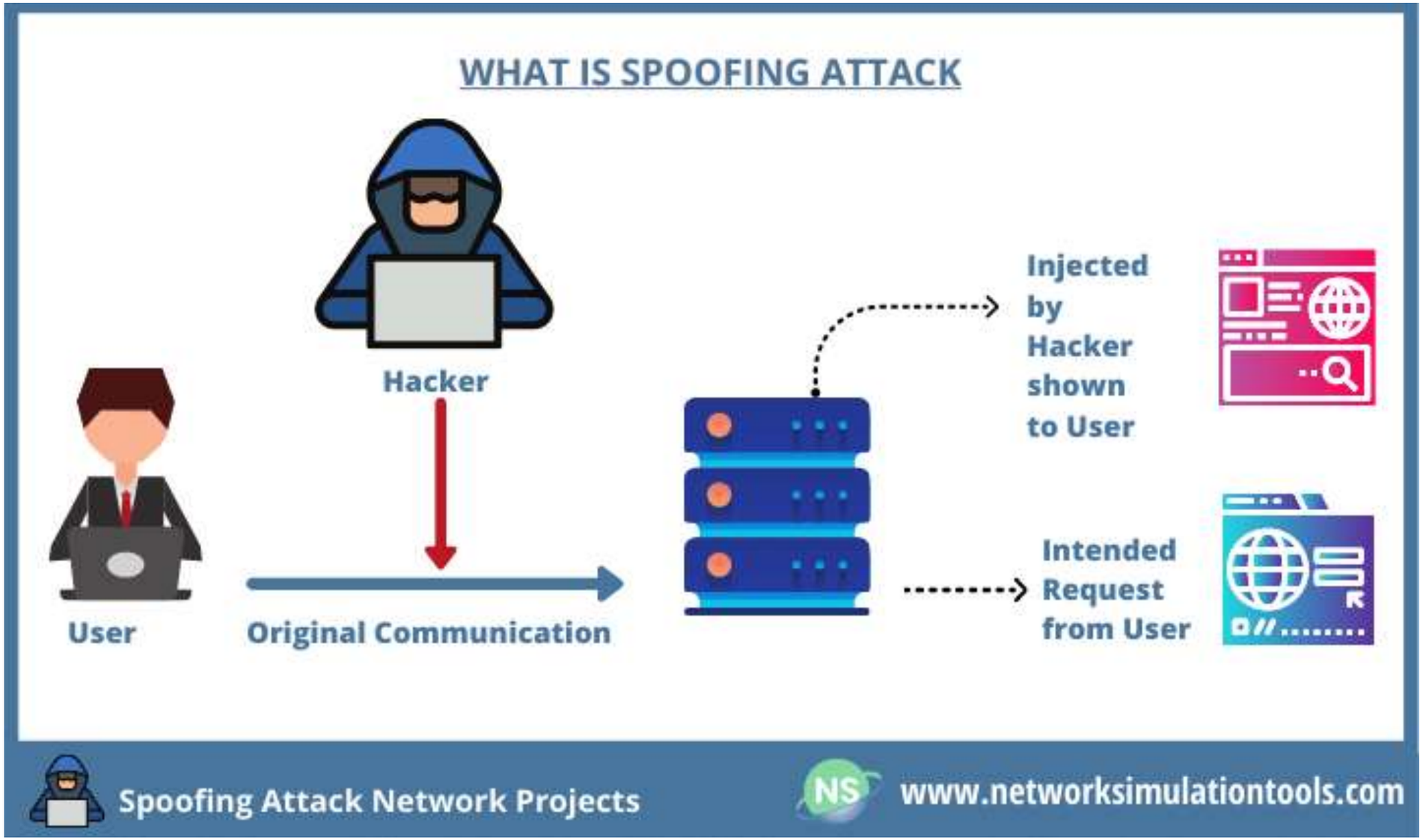
Security Attacks

- Passive Attacks
  - Release of message contents
  - Traffic Analysis
- Active Attacks
  - Masquerade
  - Replaying
  - Repudiation (Pretend to haven’t accessed/received)
  - Modification of message contents
  - Denial of Service


Eavesdropping Attack
Original Communication
Connected
to Internet
Connected
to Server
WWW
Computer User
Server
New
Connection
Eavesdropping
Attack
Hacker
Eavesdropping Attack Network Projects
NS
www.networksimulationtools.com

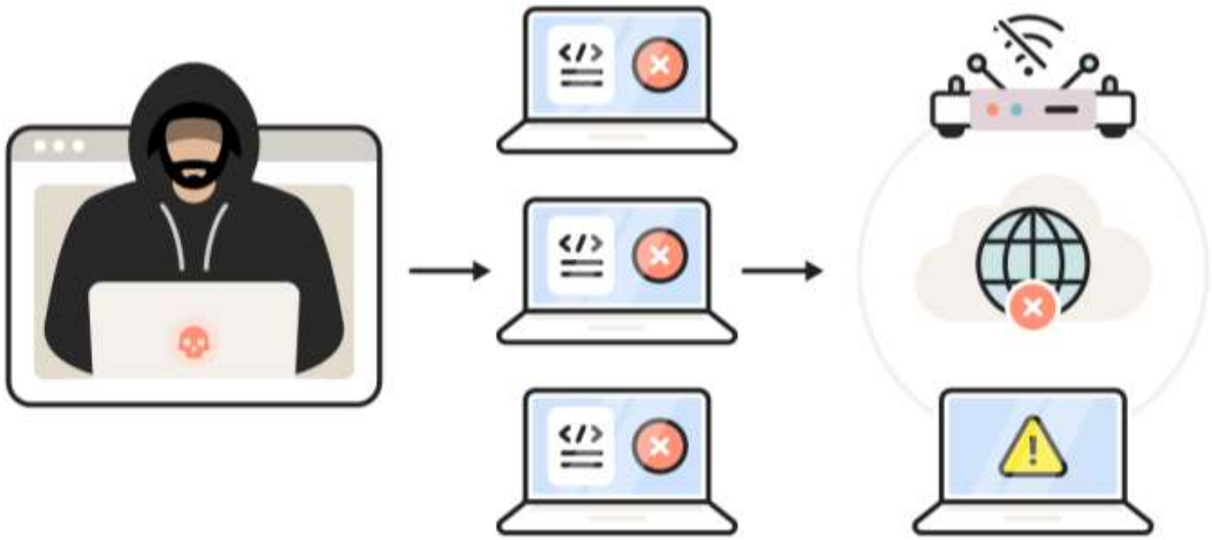

How Masquerade Attack Works
Jack
(Daniel Friend)
Internet
Or
Other Comms
Hacker Darth
Daniel
Message From
Hacker Darth
that appears
to be from
Jack
Masquerade Attack
Network Projects
NS
www.networksimulationtools.com


WHAT IS REPLAY ATTACK
Original Communication
User
Server
MITM/ Replay
Traffic
Sniff
Communication
Replay Attack Network Projects
NS
www.networksimulationtools.com


WHAT IS SPOOFING ATTACK
Hacker
User
Original Communication
Injected by Hacker shown to User
Intended Request from User
Spoofing Attack Network Projects
NS
www.networksimulationtools.com

DDoS Attacks Explained

DDoS attacks occur when a hacker uses a zombie network to flood a website/server with traffic or requests until it crashes.



Attacker

A hacker infects devices to make botnets, forming a **zombie network**.

Zombie Network

The zombie network **floods a targeted website or server** with traffic.

Targeted Website/Server

The targeted **website or server crashes**, disconnecting from the internet.

1. Repudiation of Origin (Top part of the diagram):

•Meaning:

The sender denies that they **ever sent** the transaction.

•Example:

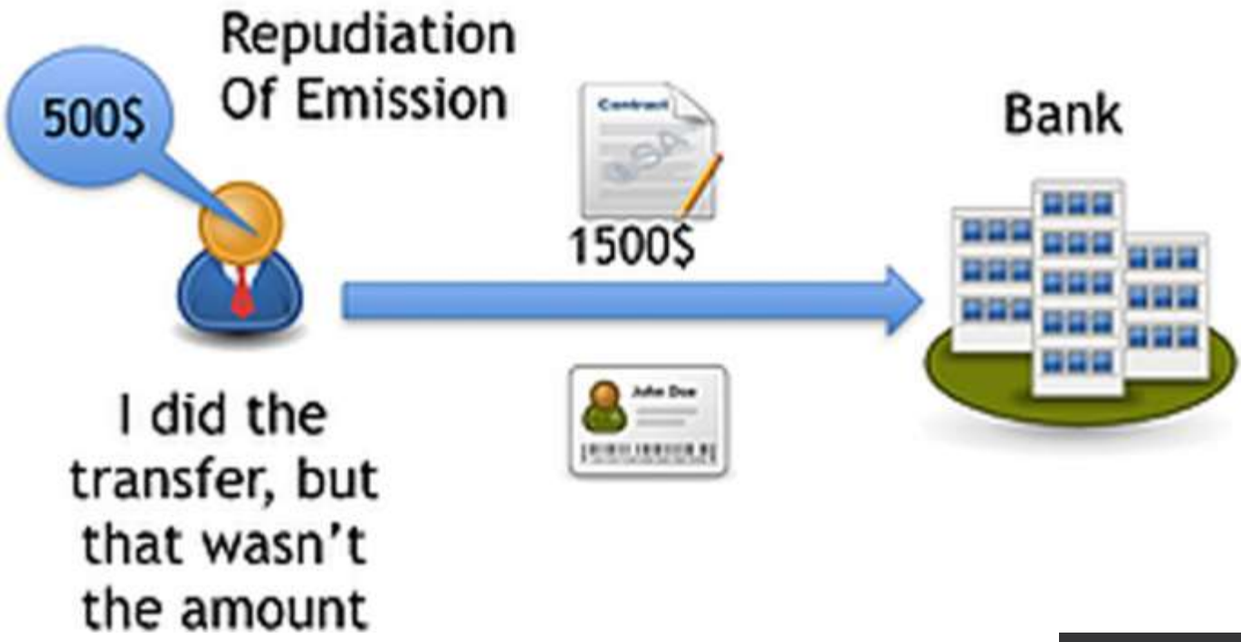
The person says, *"I didn't send that transfer."*

•Impact:

They try to avoid responsibility for the transaction, making the bank believe that someone else may have performed the action fraudulently.

•Goal:

To claim, "This transaction is not mine."



2. Repudiation of Emission (Bottom part of the diagram):

•Meaning:

The sender agrees that they **did make the transfer** but claims the **details were changed** (like the amount).

•Example:

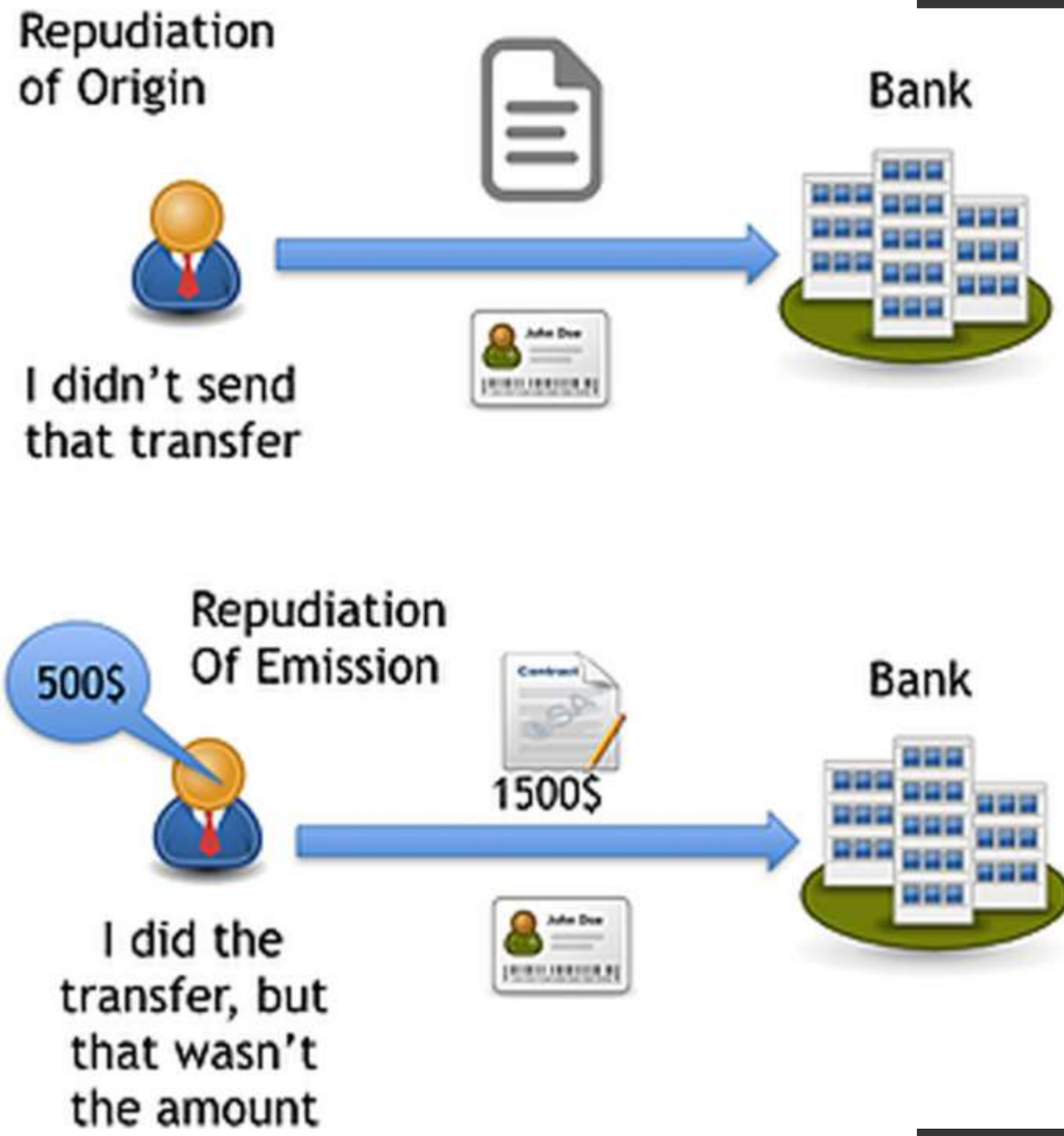
The person says, *"I did the transfer, but that wasn't the amount."*

For example:

- The user claims they sent **$500**.
- But the bank processed **$1500**.

•Impact:

They deny the **content or accuracy** of the action.



Security Service

- A processing or communication service that enhances the security of the data processing systems and the information transfer for an organization.
- The services are intended to defy security attacks, and they make use of one or more security mechanisms to serve the purpose.
- Often replicates functions normally associated with physical documents
  - which, for example, have signatures, dates; need protection from disclosure, tampering, or destruction; be witnessed; be recorded or licensed.

Security Service

- Message Confidentiality
- Authentication
- Non-repudiation
- Access Control
- Data Integrity

Security Mechanisms

- Feature designed to detect, prevent, or recover from a security attack.
- There is no single mechanism to provide security of the data to be transmitted.
- However, the element that underlies most of the security mechanisms is the use of cryptographic techniques.
- Cryptography is the art of secret writing, is the process of converting information, such as this slide, that can be read by most, into a secret code, that can only be read by those who are party to the secret.

Security Mechanisms

Encipherment

This is the process of using mathematical algorithms to transform data into a form that is not readily intelligible.

Digital Signature

Data or cryptographic transformation of a data unit is appended to the data, so that the recipient of the data unit is convinced of the source and integrity of the data unit and this can also serve to protect the data against forgery (e.g., by the recipient)

Security Mechanisms

Access Control

A variety of mechanisms are available that enforce access rights to resources.

Data Integrity

A variety of mechanisms may be used to assure the integrity of a data unit or stream of data units

Authentication Exchange

This is a mechanism intended to ensure the identity of an entity by means of information exchange.

Traffic Padding

The insertion of bits into gaps in a data stream is called traffic padding. This helps to prevent traffic analysis attempts.

Security Mechanisms

Routing Control

Enables selection of particular physically secure routes for certain data transmission and allows routing changes, especially when a breach of security is suspected.

Notarization

This is the use of a trusted third party to assure certain properties of a data exchange.

- Imagine you sign an online contract.
  A digital notarization service stamps the contract with:
  - The exact **time and date**.
  - The **identity of the signer**.
  - A **digital signature** proving its authenticity.

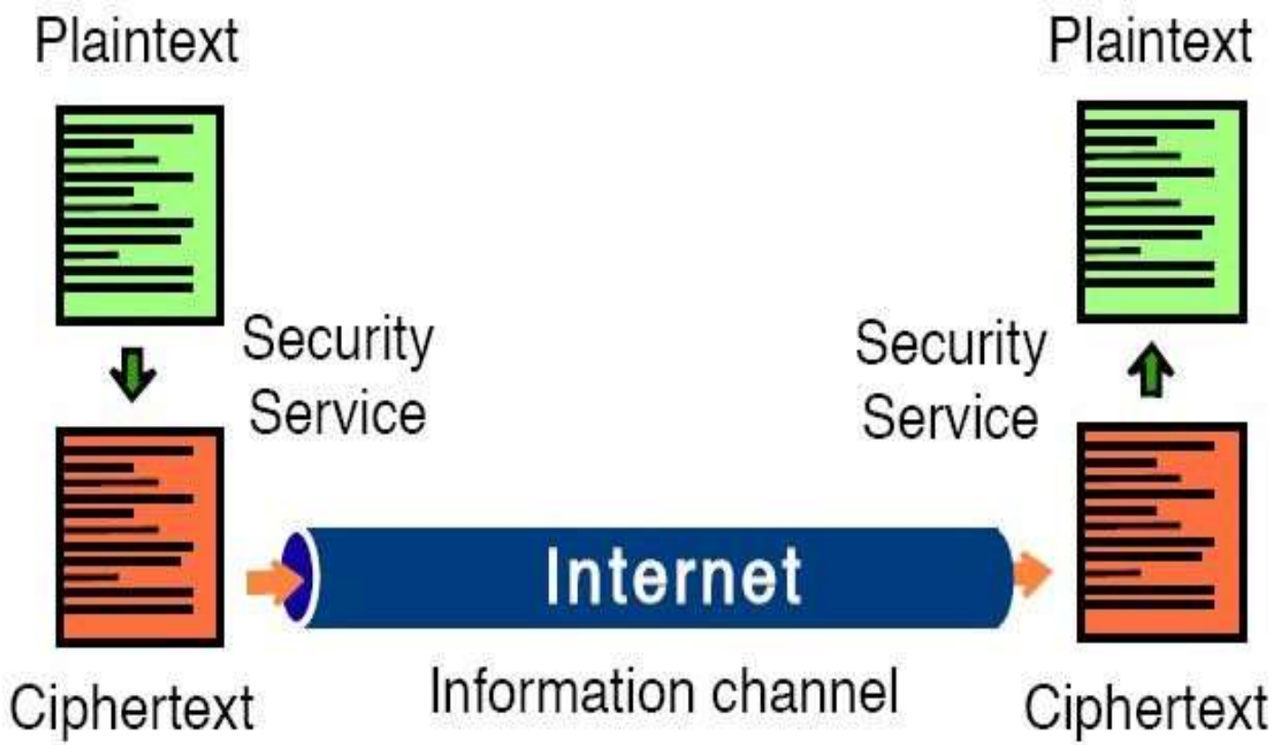
plaintext	original message
encryption	encoding the message to hide its contents
ciphertext	encrypted message
decryption	retrieving the plaintext from the ciphertext
key	is used by the encryption and decryption. The decryption can be performed only by knowing the proper key

Security Mechanisms

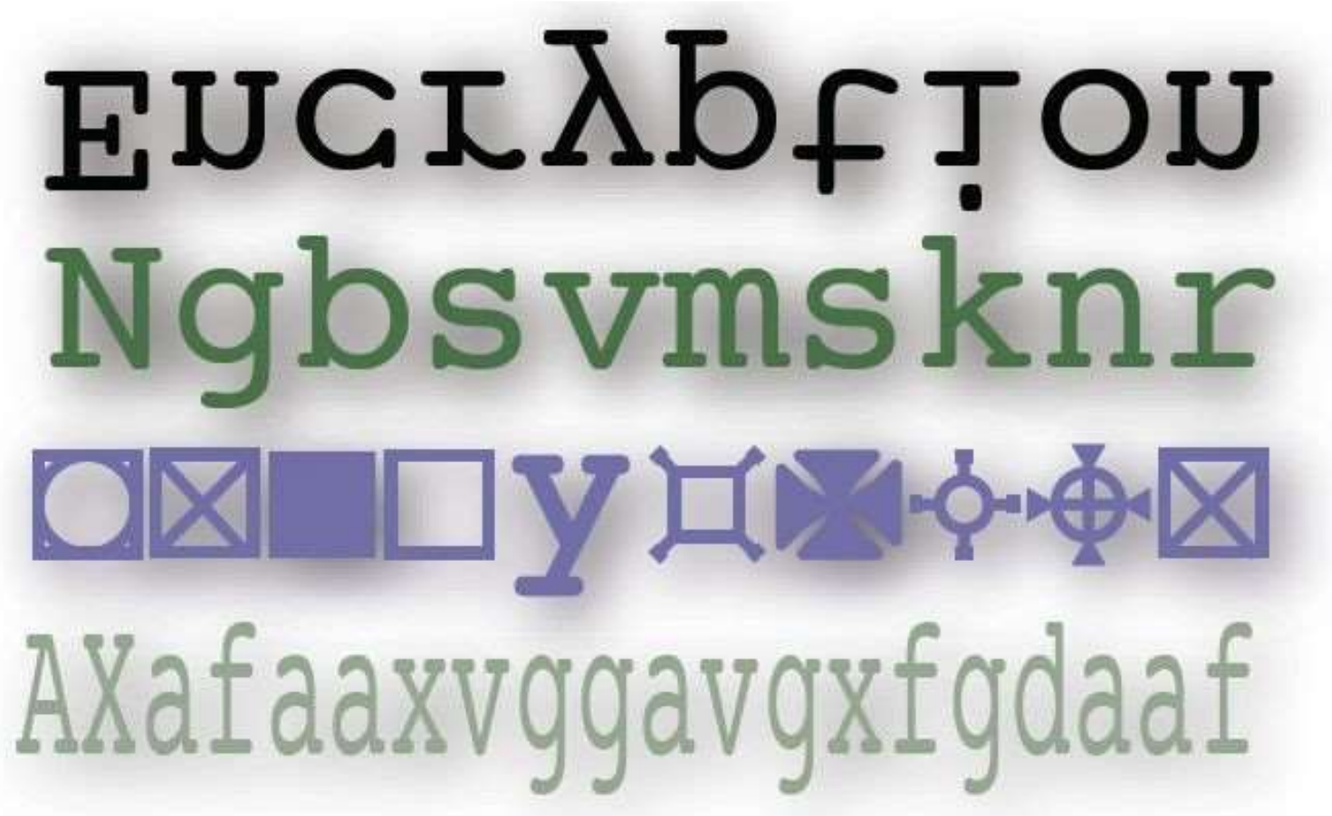
Encryption	confidentiality, authentication, integrity protection
Check/Hash algorithms	integrity protection, authentication
Digital signatures	authentication, integrity protection, non–repudiation

Insecure Communication

Security coming into play



Encryption



Cryptography

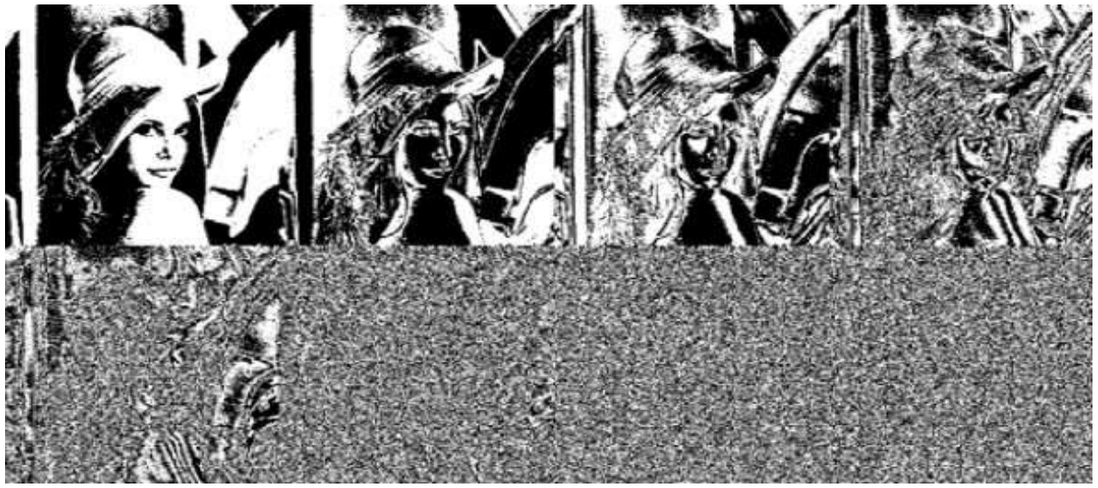
- Cryptography means secret writing.
- In cryptography, the sender does not send a message directly to the receiver
- Before sending information to the receiver information or plain text is converted into cipher text by using some encryption algorithm
- Then sent to the receiver and the receiver decrypts the cipher text into plain text to read the original information.

Steganography

- https://youtu.be/iUNUjqSXWj0?si=meYdqjmWG3kHQGfu
- Steganography is a method in which a secret message is hidden in a cover media. Steganography means covered writing. Steganography is the idea of preventing secret information by creating suspicion. Steganography is less popular than Cryptography. In steganography, the structure of data is not usually altered.
- The forms of steganography are:
  - Text
  - Audio
  - Video
  - Images
  - Network or Protocol

Steganography

- Change the LSB of pixels in a random walk.
- Change the LSB of subsets of pixels (i.e. around edges).
- Increment/Decrement the pixel value instead of flipping the LSB.

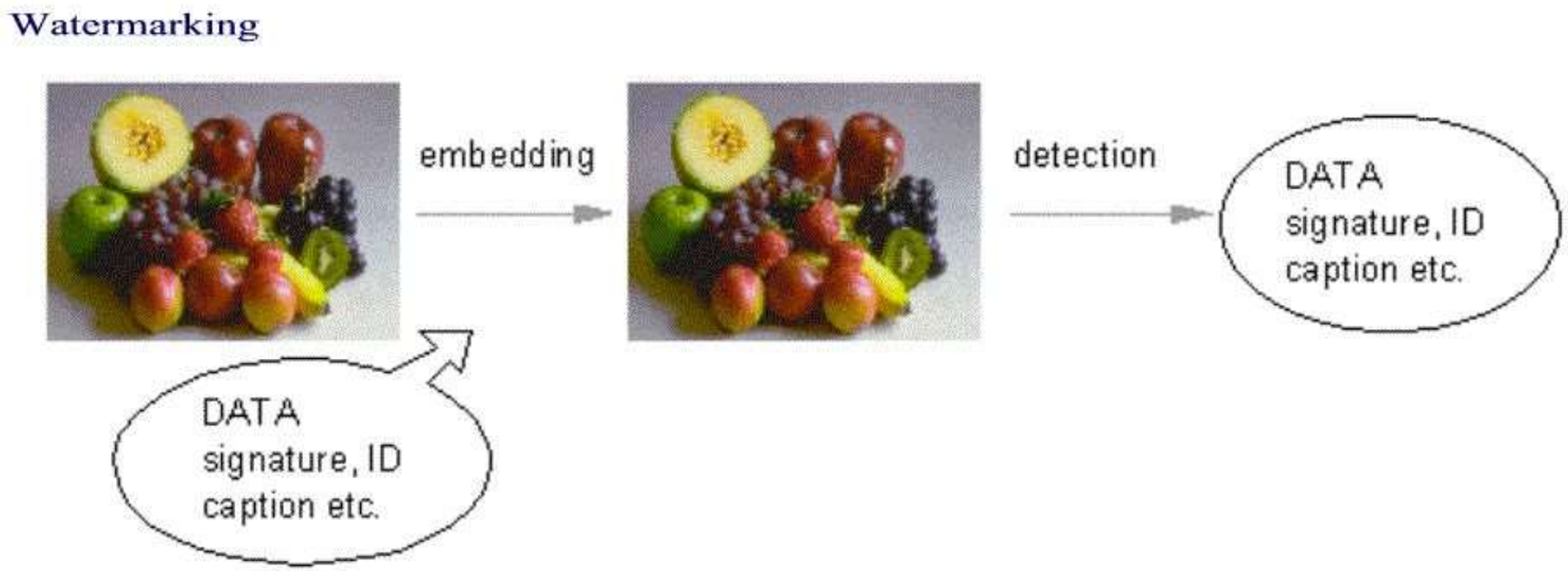


Digital Watermarking?

Allows users to embed some data into digital contents

- When data is embedded, it is not written at header part but embedded directly into digital media itself by changing media contents data

How It Works



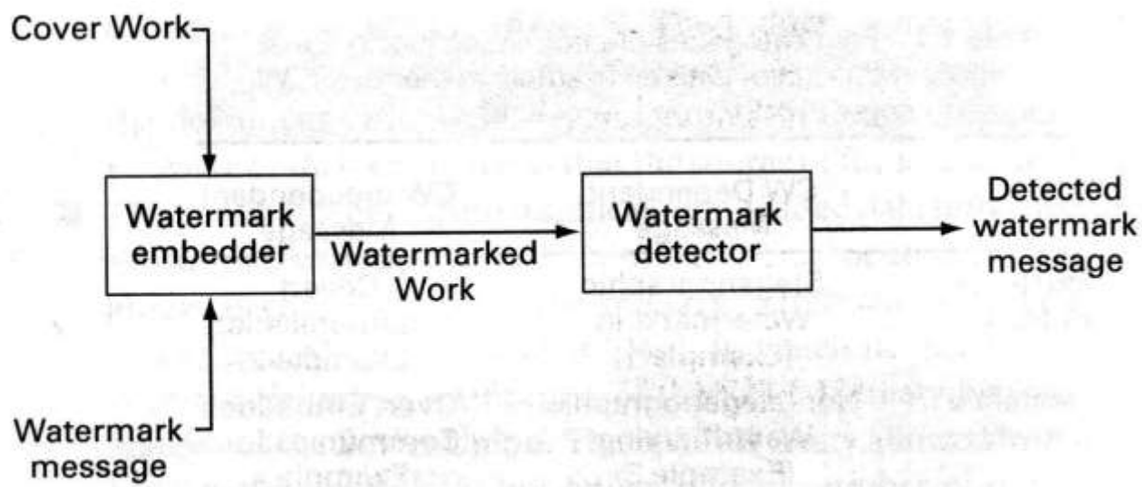
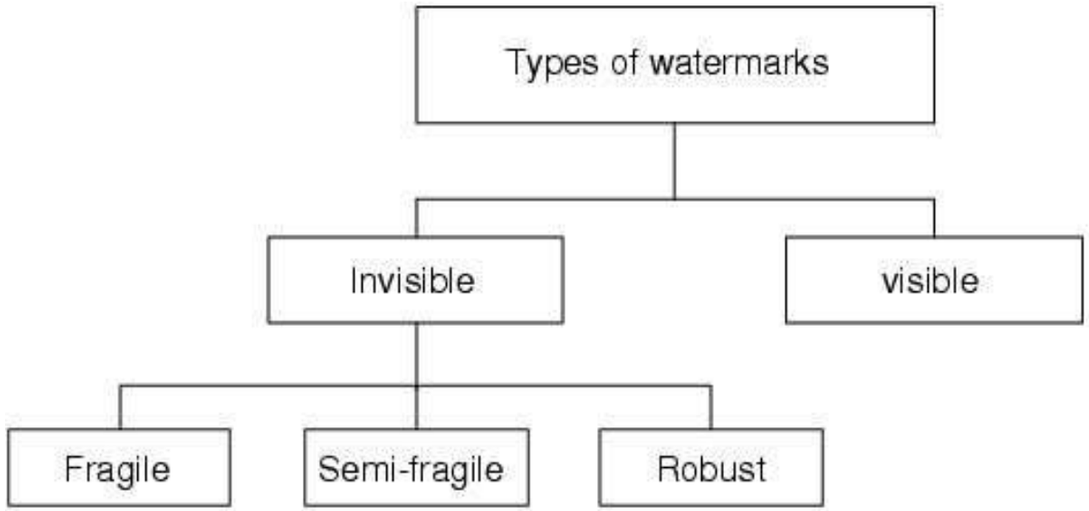


Fig. 1.2 A generic watermarking system.

Types of Watermark

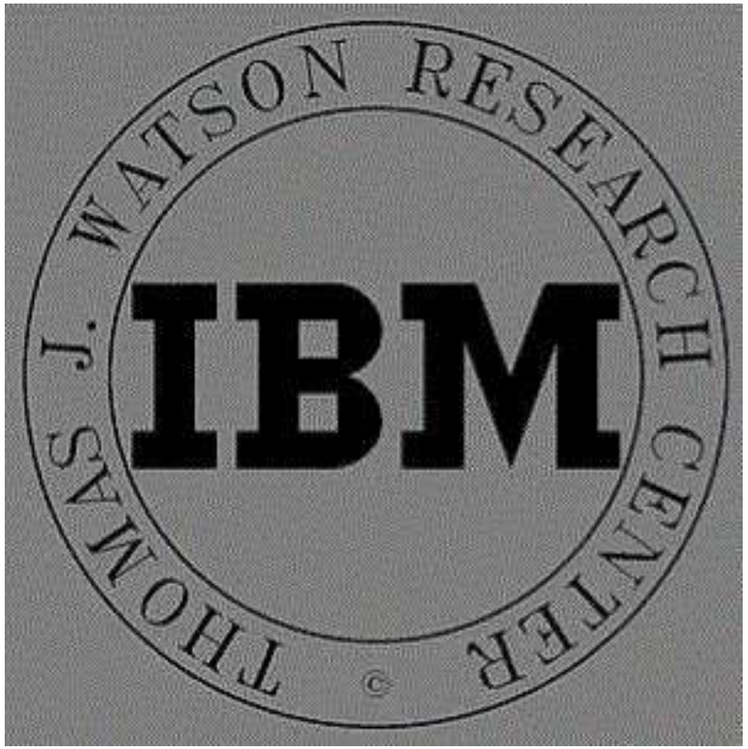
- Visible
  - A visible translucent image which is overlaid on the primary image
- Invisible
  - An overlaid image which cannot be seen, but which can be detected algorithmically

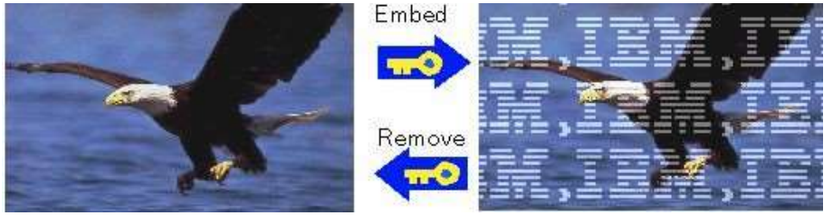


Visible Watermark

- Logo or seal of the organization which holds the rights to the primary image, it allows the primary image to be viewed, but still marks it clearly as the property of the owning organization.
- Overlay the watermark in a way which makes it difficult to remove, if the goal of indicating property rights is to be achieved.

Visible Watermark

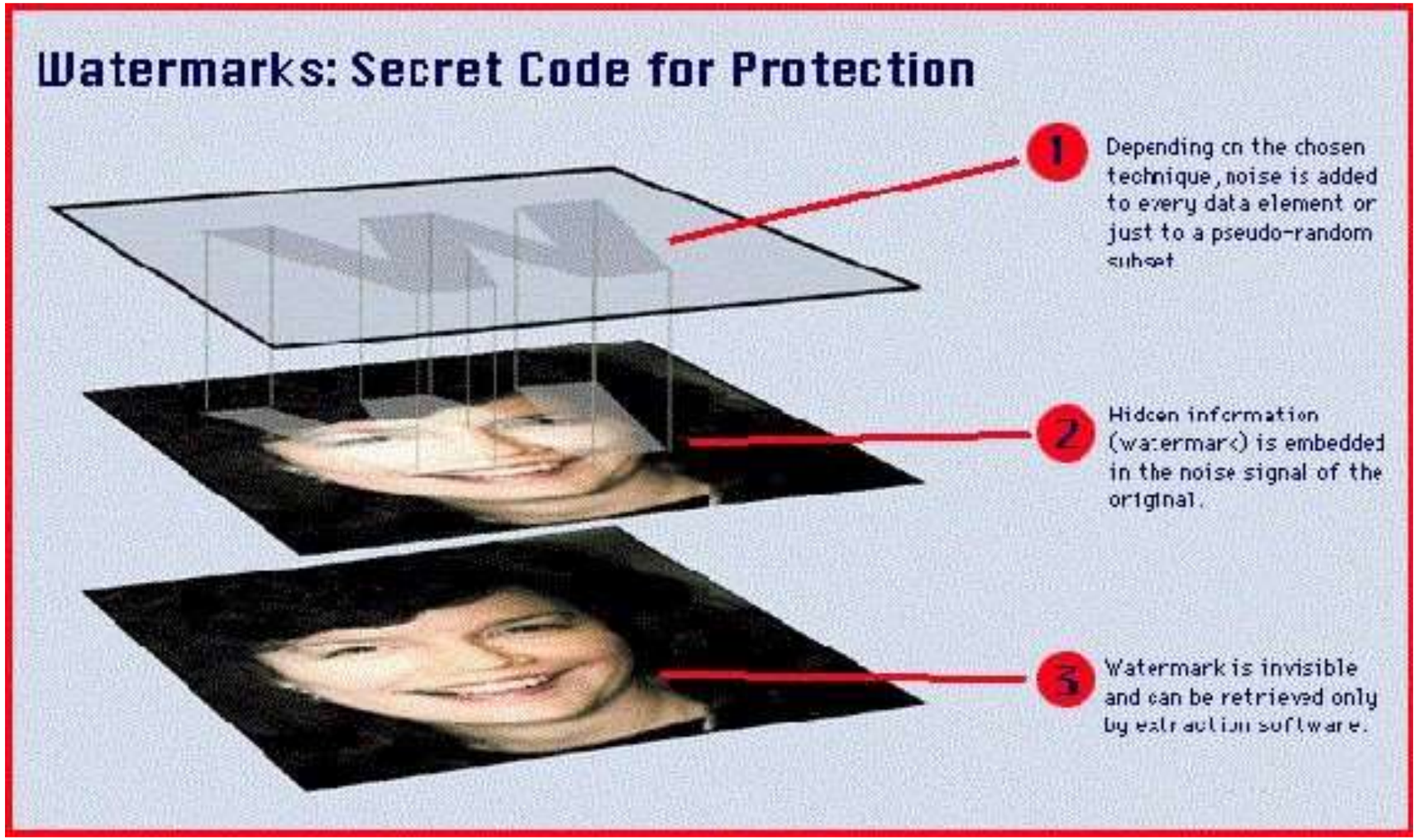




Invisible Watermark

- Embedding level is too small to notice
- Can be retrieved by extraction software
- Applications:
  - Authentication
  - Copyrighting
  - Etc…

Invisible Watermark



Threats

- Cyber threats, in the realm of cybersecurity, refer to potential risks or attacks that can compromise the confidentiality, integrity, or availability of information systems and networks.
- These threats encompass a wide range of malicious activities, techniques, and tools used by threat actors to exploit vulnerabilities in technology, processes, and human behavior.

Threats

Cyber threats can be categorized into four main categories:

- External threats
- Internal threats
- Social engineering threats
- Malware threats.
- It is crucial for organizations and individuals alike to have a comprehensive understanding of these threat categories in order to proactively identify and manage cyber threats.

social engineering

- Social engineering is a category of threats that involves the manipulation of individuals to gain unauthorized access or extract sensitive information. This form of attack relies on psychological manipulation rather than technical vulnerabilities.

Types of Social engineering attacks

- Phishing Emails: Attackers send fraudulent emails appearing to be from trusted sources, such as banks or online retailers, to trick recipients into sharing personal information or clicking on malicious links.
- Scareware: Also known as fake antivirus software, scareware tricks users into believing their system is infected with viruses. They are then prompted to purchase fake software or share personal information to resolve the perceived threat.

Malware

- Malware, short for malicious software, is a broad term used to describe various types of harmful software that are designed to disrupt, damage, or gain unauthorized access to computer systems. It encompasses a range of threats such as viruses, worms, ransomware, and more.

- The impact of malware on systems can be severe. It compromises the confidentiality, integrity, or availability of data, and can cause significant financial and reputational damage. ve information.

Malware

- Malware, short for malicious software, is a broad term used to describe various types of harmful software that are designed to disrupt, damage, or gain unauthorized access to computer systems. It encompasses a range of threats such as viruses, worms, ransomware, and more.

- The impact of malware on systems can be severe. It compromises the confidentiality, integrity, or availability of data, and can cause significant financial and reputational damage. ve information.

Malware

- Ransomware, for example, encrypts files on a victim's computer and demands a ransom for their release.
- Viruses, on the other hand, attach themselves to legitimate program files and replicate when the infected program is executed.
- Worms are self-replicating malware that exploit vulnerabilities to spread across networks.